

📖 Manual Oficial da Plataforma Cortex TIP

Guia completo de engenharia, administração de infraestrutura e procedimentos operacionais para analistas de SOC e administradores de Threat Intelligence.



Versão: 2.5 (SOC Production)



Stack: Python 3.13 / Flask / PyMISP / SQLite



LLMs: Ollama Local (DeepSeek-R1 / Qwen)



Hardening Auditado (100% Mitigado)



1. Visão Geral da Plataforma

O **Cortex TIP (Threat Intelligence Platform)** é uma solução de inteligência de ameaças concebida para atuar como o ponto central de coleta, correlação, investigação e defesa perimetral em Centros de Operações de Segurança (SOC).



Sincronização Híbrida MISP

Conexão ultra-rápida via leitura direta do MySQL para bancos volumosos aliada à API REST oficial do PyMISP para operações de escrita segura.



Analista SOC com IA

Inteligência Artificial generativa operando localmente no Ollama (DeepSeek-R1, Qwen2.5) gerando vereditos e regras de contenção para Firewalls e EDRs.



Grafo de Correlação

Visualização dinâmica em malha interativa relacionando o IOC analisado a campanhas, táticas MITRE ATT&CK e infraestrutura de rede.



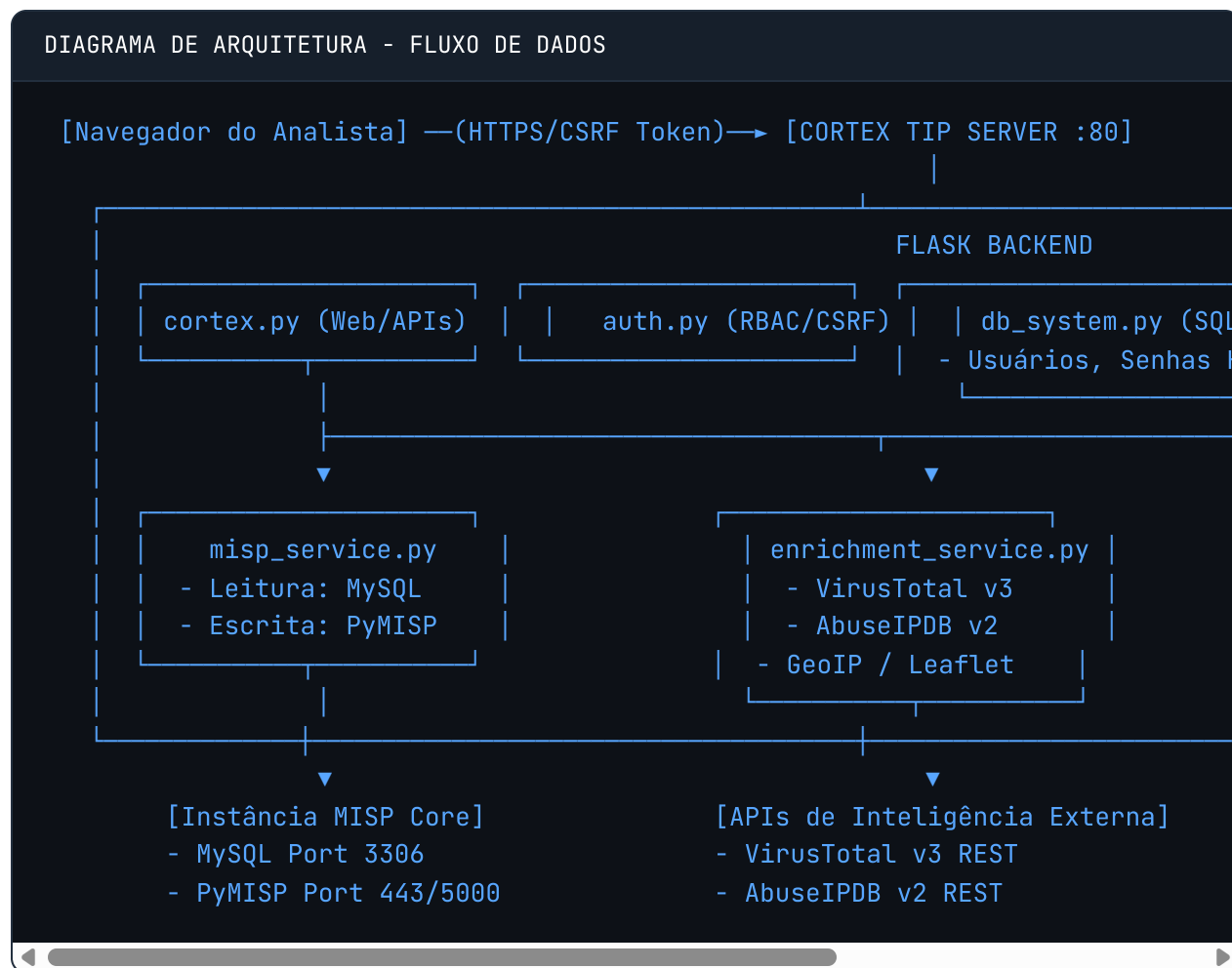
Defesa Ativa Perimetral

Listas e feeds limpos em tempo real prontos para consumo por Firewalls (Fortinet, pfSense, Palo Alto), DNS RPZ e ferramentas de SIEM.



2. Arquitetura de Componentes

A arquitetura foi projetada para ser leve, soberana e livre de dependências pesadas externas, operando de forma autônoma:



3. Requisitos de Sistema & Instalação

Requisitos de Hardware e Software

Recurso	Mínimo Recomendado	Ambiente de Produção Recomendado
Sistema Operacional	Linux (Ubuntu 22.04 LTS / Debian 12 / Rocky 9) ou Windows Server	Linux Ubuntu 22.04 / 24.04 LTS x86_64
Processador (CPU)	2 vCPUs	4 a 8 vCPUs (ou GPU NVIDIA para aceleração de LLM)
Memória RAM	4 GB (se Ollama estiver em servidor remoto)	16 GB a 32 GB (se Ollama rodar localmente com DeepSeek-R1)
Python	Python 3.10 ou superior	Python 3.11, 3.12 ou 3.13

> Passo a Passo de Instalação

```

TERMINAL / BASH

# 1. Clonar ou copiar o diretório do projeto:
cd /opt/cortex

# 2. Criar e ativar o ambiente virtual Python:
python3 -m venv venv
source venv/bin/activate # No Windows: venv\Scripts\activate

# 3. Instalar as dependências oficiais:
pip install flask requests pymisp mysql-connector-python

# 4. Iniciar a plataforma Cortex TIP:
python cortex.py

```

✔ **Criação Automática de Banco:** Você não precisa executar scripts SQL manuais. Ao iniciar, a função `db_system.init_db()` verifica e cria o arquivo `cortex_system.db` com todas as tabelas e índices necessários automaticamente.



4. Primeiro Acesso & Provisionamento Inicial (/setup)

O Cortex opera com um fluxo de inicialização protegido (estilo Portainer):

1

Acesso Inicial ao Navegador

Ao abrir `http://<IP_DO_SERVIDOR>/` no navegador com o banco recém-criado, o sistema detecta que não existem contas e redireciona automaticamente para `/setup`.

2

Definição da Credencial Mestra (Super Admin)

Informe o Nome, Sobrenome, E-mail corporativo e a Senha Mestra do primeiro Administrador.

3

Política de Senha Forte Mandatória

Por conformidade com os controles de segurança (VULN-09), a senha mestre deve possuir no mínimo **12 caracteres**, contendo letras maiúsculas, minúsculas, números e caracteres especiais.

4

Bloqueio Permanente da Rota

Assim que o administrador inicial é criado, o sistema efetua o login automático e fecha permanentemente a rota `/setup` contra novos cadastros.



5. Gestão de Usuários e Perfis de Acesso (RBAC)

Perfil / Role	Nível de Privilegio	Permissões Concedidas
 ADMIN	Total	Acesso irrestrito a configurações de sistema, chaves de API, gestão de usuários, ingestão de IOCs e auditoria.
 ANALISTA	Operacional	Busca de IOCs, enriquecimento de inteligência, acionamento do Analista IA, cadastro de novos IOCs no MISP e consulta de auditoria.
 VISUALIZADOR	Somente Leitura	Visualização do Dashboard, mapas de calor, feeds de notícias (THN/Bleeping) e consumo de listas públicas JSON.

Gerenciamento via Modais (/users)

O Administrador pode gerenciar os operadores sem recarregar a tela:

Novo Usuário:

Editar Usuário:

Desativar Acesso:

Excluir Usuário:



6. Painel de Configurações Administrativas (/settings)

Acessível apenas por administradores para parametrizar integrações externas:

1. Integração com o MISP

Parâmetro	Tipo / Descrição	Finalidade
<code>misp_read_mode</code>	Seletor: <code>database</code> ou <code>api</code>	Define se a leitura/sincronização será feita via banco MySQL (recomendado) ou via chamadas REST da API.
<code>misp_url</code>	URL (Ex: <code>https://misp.corp.local</code>)	Endereço da instância do MISP para criação de eventos oficiais via PyMISP.
<code>misp_api_key</code>	Token Alfanumérico de 40 caracteres	Chave de automação criada no MISP para a conta de serviço do Cortex.
<code>misp_mysql_*</code>	Host, Porta (3306), Usuário, Senha e Banco	Credenciais para conexão direta no MySQL do MISP para indexação em alta performance.

2. Inteligência Artificial (Ollama / LLMs)

O Cortex suporta provedores locais soberanos (sem saída para internet) ou em nuvem:

Provedor Padrão: `Ollama Local`

URL do Ollama: `http://localhost:11434`

Botão "Detectar Modelos":

`deepseek-r1:8b` `qwen2.5-coder:7b`

Provedores em Nuvem (Opcionais):

3. Enriquecimento Externo (VirusTotal & AbuseIPDB)

VirusTotal v3 API Key:

AbuseIPDB v2 API Key:



7. Dashboard & Inteligência Contínua (/)

A tela inicial do Cortex foi desenhada para operadores de SOC monitorarem o cenário de ameaças em tempo real:



Mapa Dark de Ameaças

Miniaturas e marcadores proporcionais à densidade de ataques por país, permitindo identificar focos geográficos de origem.



Cyber News Feed (24h)

Ingestão automática dos principais portais de notícias de segurança (*The Hacker News* e *BleepingComputer*) atualizados a cada recarga.



Catálogo CISA KEV

Exibição prioritária de vulnerabilidades com exploração ativa no mundo (*Known Exploited Vulnerabilities*) para direcionar correções do time de infraestrutura.



8. Busca Avançada, Enriquecimento e Analista SOC IA (/search)

A ferramenta principal de triagem e investigação do analista de segurança:

1

Consulta Unificada de Indicadores

O campo aceita qualquer tipo de IOC: IPs IPv4/IPv6, FQDNs, URLs completas ou Hashes criptográficos (MD5, SHA1, SHA256). A plataforma busca correlações locais no banco de eventos do MISP.

2

Enriquecimento Automático Multi-Bases

Ao acionar a busca, dados reputacionais do VirusTotal (taxa de detecção x/70), AbuseIPDB (score de abuso e denúncias), ASN e localização geográfica com mapa interativo Leaflet são apresentados de forma condensada.

3

Grafo de Correlação Interativo

Altere entre a visualização clássica e a aba **Grafo**. O motor Vis-Network conecta em tempo real o indicador aos eventos do MISP, atributos relacionados e táticas da matriz MITRE ATT&CK.

4

Copiloto de Análise SOC com IA (Ollama)

O analista pode clicar em "**Análise do Analista SOC com IA**". O LLM avalia todos os metadados do indicador e retorna:

- **Veredito Claro:** BENIGNO, SUSPEITO ou ALTAMENTE MALICIOSO.
- **Sumário Executivo:** Explicação contextual da ameaça em linguagem técnica clara.
- **Cadeia de Raciocínio (Chain-of-Thought):** Caixa retrátil com o pensamento analítico do DeepSeek-R1.
- **Comandos de Bloqueio Imediatos:** Regras de IPTables e EDR prontas com botão de cópia com um clique.



9. Ingestão de IOCs no MISP (/add-ioc)

Permite a analistas e administradores cadastrar novos indicadores diretamente no MISP oficial com conformidade e governança:

Campo	Comportamento
Category	Categorias oficiais do MISP (<i>Network activity, Payload delivery, Antivirus detection, External analysis, etc.</i>).

Campo	Comportamento
Type	Filtro dinâmico que exibe apenas tipos compatíveis com a categoria selecionada (<i>ip-dst, ip-src, domain, url, md5, sha256</i>).
Distribution	Nível de sigilo e compartilhamento (<i>This community only, All communities, Inherit event</i>).
Value	Suporta entrada em lote: você pode colar centenas de indicadores (um por linha) para ingestão simultânea.
Comment	Contextualização da investigação ou número de ticket de incidente.



10. Trilha de Auditoria e Conformidade (/audit)

Todas as operações de criação de indicadores no MISP são salvas na tabela `ioc_audit_log` do banco SQLite local de forma imutável:

Operador:

Cargo:

Indicador & Categoria:

ID do Evento:

Carimbo Temporal:



11. Endpoints de Integração Perimetral para Firewalls

O Cortex disponibiliza rotas HTTP públicas para alimentação automática de listas de bloqueio (*Blocklists / Dynamic Threat Feeds*):

Endpoint	Formato de Retorno	Aplicação Prática no Perímetro
<code>GET /misp_ips.json</code>	Array JSON de IPs (["1.2.3.4", "5.6.7.8"])	Ingestão em firewalls perimetrais (pfSense pfBlockerNG, Fortinet External Threat Feeds, IPSet).
<code>GET /misp_domains.json</code>	Array JSON de Domínios	Alimentação de DNS Sinkhole, Pi- hole corporativo, AdGuard Home ou zonas DNS RPZ.
<code>GET /misp_urls.json</code>	Array JSON de URLs	Bloqueio de navegação em Web Application Firewalls (WAF) e Secure Web Gateways (SWG).
<code>GET /misp_hashes.json</code>	Array JSON de Hashes	Blacklists personalizadas de EDRs (CrowdStrike, Defender for Endpoint) e Antivírus.



12. Segurança da Plataforma & Hardening (Auditoria 100% Mitigada)

O Cortex TIP foi homologado com 9 controles de segurança ativos de nível empresarial:

ID	Controle	Mecanismo Implementado	Status
VULN-01	Interactive Debugger	Execução com <code>debug=False</code> em produção, desativando o console Werkzeug.	✓ Mitigado
VULN-02	Credenciais Hardcoded	Remoção de senhas em código-fonte; persistência estrita em banco de dados interno.	✓ Mitigado

ID	Controle	Mecanismo Implementado	Status
VULN-03	Blind SSRF	Validação estrita de esquema HTTP/HTTPS e bloqueio contra IPs de metadados de nuvem (169.254.169.254).	✓ Mitigado
VULN-04	Proteção de APIs	Endpoints <code>/api/enrich</code> e <code>/api/ai-analyze</code> protegidos com autenticação (HTTP 401).	✓ Mitigado
VULN-05	DOM Stored XSS	Sanitização de entidades com <code>escapeHtml()</code> e uso de <code>DOMPurify</code> nas saídas de Markdown.	✓ Mitigado
VULN-06	Defesa Anti-CSRF	Padrão Synchronizer Token Pattern (tokens criptográficos 256-bit com validação em tempo constante).	✓ Mitigado
VULN-07	Vazamento em Repositório	Arquivo <code>.gitignore</code> configurado para isolar <code>cortex_system.db</code> , <code>logs/</code> e arquivos <code>.env</code> .	✓ Mitigado
VULN-08	Cookies de Sessão	Flags <code>HttpOnly</code> (bloqueia XSS), <code>SameSite=Lax</code> e suporte dinâmico a <code>Secure</code> via TLS.	✓ Mitigado
VULN-09	Política de Senha	Exigência mandatória de 12 caracteres com classes de caracteres (maiúscula, minúscula, número e símbolo).	✓ Mitigado



13. Procedimentos de Backup & Migração de Servidor

1. Como Realizar Backup Completo

Toda a persistência da plataforma (usuários, hashes de senhas, chaves de API do MISP/IA/VirusTotal salvas e logs de auditoria) reside em um único arquivo:



Arquivo Único de Dados: `cortex_system.db` (localizado na raiz do projeto). Para fazer backup, basta copiar ou arquivar este arquivo para um local seguro.

2. Migração Rápida para Outro Servidor via SSH / Pen Drive

Para transferir o Cortex para outro host, copie apenas as pastas essenciais:

COMANDO DE COMPACTAÇÃO (EXCLUINDO PASTAS DESCARTÁVEIS)

```
# Compactar apenas os itens essenciais da plataforma:
tar --exclude='__pycache__' --exclude='logs' --exclude='cache' --exclude='scratch'

# Transferir para o servidor de destino via SCP:
scp cortex_deploy.tar.gz usuario@ip-servidor:/opt/cortex/
```